

Clase 100 — XML External Entities (XXE)

Parte: 4 — Seguridad de aplicaciones web · Fuente: *The Web Application Hacker's Handbook* / OWASP

 Duración estimada: 100 min · Nivel: Avanzado

Objetivo

Explotar vulnerabilidades **XXE (XML External Entities)**: abusar de parsers XML mal configurados para leer archivos locales, provocar SSRF y, en casos ciegos, exfiltrar datos out-of-band. Es un fallo clásico que sigue apareciendo en importadores, SOAP, SAML y formatos basados en XML.

 **Ética:** solo en labs propios/autorizados. Leer archivos del servidor ajeno es un delito.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** qué son las entidades externas y por qué son peligrosas.
2. **Leer** archivos del servidor con XXE in-band.
3. **Provocar** SSRF a través de entidades externas.
4. **Exfiltrar** datos con XXE ciega y DTD externo (OOB).
5. **Configurar** parsers para deshabilitar entidades externas (defensa).

Temas

#	Tema	Por qué importa
1	XML, DTD y entidades	Base del ataque
2	Entidades externas	El vector principal
3	Lectura de archivos locales	Impacto directo
4	XXE → SSRF	Encadenar impactos
5	XXE ciega y OOB con DTD externo	Exfiltración sin salida
6	XXE en SAML, DOCX, SVG	Superficie oculta
7	Defensa: deshabilitar DTD/entidades	Cierre del fallo

Definiciones y características

- **XXE:** abuso de entidades externas en un parser XML. Característica: permite leer archivos y hacer SSRF.

- **DTD (Document Type Definition)**: define estructura y entidades del XML. Característica: donde se declaran las entidades externas.
- **Entidad externa**: referencia a un recurso externo (`SYSTEM "file:///etc/passwd"`). Característica: el parser la resuelve si no está deshabilitada.
- **XXE ciega**: no hay salida directa; se usa DTD externo para exfiltrar. Característica: requiere servidor del atacante.
- **Parameter entity** (`%`): entidad usada dentro del DTD. Característica: clave para exfiltración OOB.
- **Deshabilitar DTD**: configurar el parser para no procesar entidades. Característica: defensa definitiva.

Herramientas y preparación

- **PortSwigger labs** de XXE y **Juice Shop** (reto de XXE).
- **Burp** para editar cuerpos XML.
- Servidor propio para alojar el DTD externo en XXE ciega.

Laboratorio guiado

 Solo en labs propios.

1. Encuentra un endpoint que acepte XML (importar datos, SOAP, comprobar stock).
2. Inyecta una entidad externa para leer un archivo:

```
<?xml version="1.0"?>
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<stockCheck><productId>&xxe;</productId></stockCheck>
```

3. Observa el contenido del archivo reflejado en la respuesta.
4. Convierte el XXE en **SSRF** apuntando la entidad a `http://169.254.169.254/ ...`.
5. Para XXE **ciega**, aloja un DTD externo en tu servidor y usa parameter entities para exfiltrar por HTTP/OOB.
6. Prueba XXE en un archivo **SVG** o **DOCX** subido (son XML por dentro).
7. Documenta el archivo leído, el vector y el impacto.

Ejercicios

1. Lee `/etc/hostname` y `/etc/passwd` en el lab y explica la diferencia de impacto.
2. Transforma un XXE de lectura en un SSRF a metadata.
3. Construye el DTD externo para una XXE ciega OOB.
4. Investiga cómo un SVG subido puede desencadenar XXE.
5. Escribe la configuración segura de un parser en Java/Python que deshabilite DTD.
6. Explica por qué SAML es históricamente vulnerable a XXE.

Reto verificable

Resuelve un lab de **XXE ciega** de PortSwigger exfiltrando el contenido de un archivo del servidor mediante un DTD externo alojado por ti. **Criterio de aceptación**: el lab queda resuelto, entregas el DTD externo, el payload y el dato exfiltrado, y explicas la configuración de parser que lo evitaría.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
La entidad no se resuelve	Parser con entidades deshabilitadas; busca otro endpoint
Error de sintaxis XML	DTD mal formado; valida la estructura
Sin salida del archivo	XXE ciega; usa DTD externo OOB
DTD externo no se carga	El servidor no permite conexiones salientes
Parameter entity ignorada	Restricciones del parser; ajusta la técnica

Preguntas frecuentes

 **¿Por qué sigue existiendo XXE si es antiguo?** Porque muchos parsers procesan DTD por defecto y XML se esconde en SAML, SVG, DOCX y APIs SOAP.

 **¿JSON es inmune?** JSON no tiene entidades externas, así que no sufre XXE. Pero otras inyecciones sí aplican.

 **¿Cuál es la defensa definitiva?** Deshabilitar el procesamiento de DTD y entidades externas en la configuración del parser.

Referencias

- Stuttard & Pinto, *The Web Application Hacker's Handbook*, cap. 9.
- OWASP XXE: [https://owasp.org/www-community/vulnerabilities/XML_External_Entity_\(XXE\)_Processing](https://owasp.org/www-community/vulnerabilities/XML_External_Entity_(XXE)_Processing)
- OWASP XXE Prevention Cheat Sheet.
- PortSwigger XXE: <https://portswigger.net/web-security/xxe>

Siguiente clase

Clase 101 - Fallos de autenticacion y bypass